VIVA VOCE DEFENSE MASTER MANUAL & Q&A CHEAT SHEET

Candidate: S.M. Dissanayaka (IT23368248) | **Component:** Component 03: Protocol Anomaly Detection for MITM Attacks | **Project:** J26-CS-330

CATEGORY 1: RESEARCH SCOPE & INDIVIDUAL BOUNDARY

Q1: What is YOUR individual contribution in this group project, and where does your scope end?

[5-Second Hook] Detection & Alerting is my part (99.54% Acc, 0.004 ms speed); Mitigation (dropping flows) is Member 4's SDN part.

[Spoken Script] "Sir/Madam, my individual component is Protocol Anomaly Detection for MITM Attacks in IoMT Networks. My contribution is a 4-stage pipeline that classifies IoMT traffic, verifies MQTT protocols, detects anomalies using Random Forest (99.54% accuracy), and correlates MITM vectors with clinical patient vitals. My scope strictly ends at Threat Detection and Structured Alert Dispatch. The actual network mitigation (dropping flows or OpenFlow switch rules) is handed over to Team Member 4 via our REST API contract."

• **What I Own:** Stage 1 (IoMT Classification), Stage 2 (MQTT Verification), Stage 3 (Random Forest ML), Stage 3.5 (Deterministic MITM Engine), and Stage 4 (Clinical Alert Stream).

• **Handover Point:** Clean REST API JSON payload dispatching threat type and SDN action advisory.

• **Boundary:** I do NOT write OpenFlow switch rules or control SDN controllers; that belongs to Member 4.

Q2: Why did you focus specifically on MITM attacks instead of Ransomware or DDoS?

[5-Second Hook] MITM attacks are silent and deadly in ICUs; they tamper with vital signs while keeping monitors looking 'Normal'.

[Spoken Script] "Because in hospital ICUs, MITM is a silent killer. Ransomware shuts down servers visibly, alerting staff immediately. But a stealthy MITM attack silently modifies in-transit telemetry—such as injecting an insulin overdose or faking normal sinus rhythm—while displays stay green. Clinicians only realize an attack occurred after the patient suffers irreversible cardiac or brain death."

• **Silent Deception:** Adversary exploits unauthenticated MQTT or ARP spoofing to alter payload bytes.

• **Catastrophic Morbidity:** Induces acute hypoglycemic coma, cardiogenic shock, or undetected hemorrhage.

• **Research Gap:** Traditional IDS tools catch loud volumetric floods but fail on subtle, low-rate MITM tampering.

CATEGORY 2: MACHINE LEARNING & PIPELINE ARCHITECTURE

Q3: Why did you choose Random Forest instead of Deep Learning (like LSTM or CNN)?

[5-Second Hook] Speed and tabular efficiency: Random Forest executes in 0.004 ms on CPU; LSTMs take 15-50 ms and need GPUs.

[Spoken Script] "For two critical engineering reasons: Latency and Tabular Efficiency. In an ICU, an intrusion detection system must evaluate packets in real-time. Deep learning models require 15 to 50 ms and heavy GPU acceleration. Our Random Forest ensemble evaluates in just 0.004 ms (4 microseconds) on standard CPU hardware. Furthermore, our dataset consists of tabular network flow metrics (packet rates, variance, flags), where tree ensembles consistently outperform neural networks."

• **Latency:** 0.004 ms (Random Forest) vs 25+ ms (LSTM/RNN) — crucial for sub-10ms SDN constraints.

• **Resource Footprint:** Runs lightweight on edge hospital appliances without expensive dedicated GPUs.

• **Interpretability:** Enables clear feature importance extraction, proving why an anomaly score spiked.

Q4: Explain your 4-Stage Detection Pipeline briefly.

[5-Second Hook] Filter IoMT -> Verify MQTT -> ML Anomaly Score -> Correlate MITM Vectors & Dispatch Alert.

[Spoken Script] "Our pipeline operates in 4 synchronized stages: Stage 1 filters traffic to verify it belongs to hospital medical assets (99.99% accuracy). Stage 2 heuristic checks Ports 1883/8883 to confirm the MQTT telemetry profile. Stage 3 uses Random Forest to calculate the anomaly probability score (99.54% accuracy). Stage 3.5 executes cross-layer deterministic correlation (L2 ARP, L3 DNS, L7 byte variance) to confirm MITM vectors and isolate them from DDoS floods. Stage 4 binds the anomaly to patient EHR context and dispatches structured alerts."

• **Stage 1:** Random Forest supervised filter (99.99% Acc) eliminating non-medical IT traffic.

• **Stage 2:** Flow-level port/header heuristic identifying MQTT telemetry sessions.

• **Stage 3 & 3.5:** ML anomaly evaluation + deterministic protocol flag correlation (ARP/DNS/Payload).

• **Stage 4:** Translates network packet attributes into patient bed identity and clinical risk.

Q5: How does your system differentiate a Volumetric DDoS attack from a MITM attack?

[5-Second Hook] Rate vs Spoofing flags: Rate > 50,000 pkts/s with no spoofing = DDoS; Low rate + ARP/DNS/Variance = MITM.

[Spoken Script] "Through our Stage 3.5 Rate vs Protocol Flag Discrimination Heuristic. A volumetric DDoS flood exhibits extreme packet velocity exceeding 50,000 pkts/sec without protocol tampering flags, aiming solely to exhaust switch memory buffers. A MITM attack is conversational and low-velocity (<100 pkts/sec) but contains Layer 2 gratuitous ARP conflicts, Layer 3 DNS redirects, or Layer 7 payload variance. If rate > 50k pkts/s without spoofing, we isolate it as a DDoS Queue Delay, preventing false vital tampering alerts."

• **DDoS Signature:** Velocity > 50k pkts/s, high volume, zero ARP/DNS spoofing -> Classified as Buffer Saturation.

• **MITM Signature:** Low rate, subtle packet modifications, byte length variance -> Classified as Vital Tampering.

• **Clinical Benefit:** Prevents nursing staff from confusing a network transmission delay with patient vital deterioration.

CATEGORY 3: DATASETS, FEATURE ENGINEERING & OVERCOMING OBSTACLES

Q6: Which datasets did you use, and why did you reject older datasets like KDD99?

[5-Second Hook] KDD99 is 25 years old with zero IoT/MQTT; we used the latest CICIoMT2024 merged with CICIoT2023.

[Spoken Script] "Legacy datasets like KDD99 or NSL-KDD are over two decades old and contain zero modern IoMT or MQTT medical protocols. We utilized CICIoMT2024, published by the Canadian Institute for Cybersecurity, which contains traffic from 40+ physical and simulated medical devices with authentic MITM attacks. We merged benign samples from CICIoT2023 to train our Stage 1 classifier to reliably separate medical devices from generic enterprise IoT assets like smart TVs or laptops."

• **CICIoMT2024:** 40+ medical devices, authentic ARP spoofing, DNS cache poisoning, and MQTT tampering.

• **CICIoT2023 Merge:** Provided rich negative samples (generic IT/IoT) for robust Stage 1 IoMT classification.

• **Data Hygiene:** Cleaned infinite values, handled NaN fields, and normalized feature distributions.

Q7: How did you select your features (Feature Selection)?

[5-Second Hook] Reduced 46 raw flow metrics to 10 key discriminative features to achieve 0.004 ms latency.

[Spoken Script] "Raw pcap flow files contained 46 statistical metrics, which would introduce excessive calculation delay. Using Random Forest feature importance ranking and domain expertise, we pruned this down to 10 key features: ARP flag for Layer 2 poisoning, DNS flag for Layer 3 redirection, Variance for Layer 7 payload tampering, Rate for DDoS separation, and Destination Ports 1883/8883 for MQTT verification."

• **L2/L3 Flags:** ARP (binary gratuitous flag), DNS (binary redirect flag).

• **L7 Flow Dynamics:** Variance (payload byte length jitter), Duration (connection persistence).

• **Transport Metrics:** Rate (pkts/sec), Protocol Type (TCP=6, UDP=17), Ports (1883/8883), Header Length.

Q8: How did you handle Class Imbalance in the dataset?

[5-Second Hook] Applied class weighting during training and calibrated decision threshold to 0.65 to stop false alarms.

[Spoken Script] "In hospital networks, benign flows vastly outnumber attack packets by over 95 to 5. If unaddressed, standard models predict everything as normal. We resolved this by applying class weighting (class_weight='balanced') during Random Forest training and rigorously calibrated the suspicious anomaly threshold to 0.65. This suppressed false positives to 0.0075% while maintaining a 99.56% attack sensitivity/recall."

- **Class Weighting:** Penalizes misclassifying rare attack samples during decision tree node splitting.
- **Threshold Calibration:** Shifts decision boundary to 0.65 to ensure high-confidence attack classification.
- **Result:** 99.95% Precision and 0.0075% False Positive Rate, virtually eliminating nurse alarm fatigue.

CATEGORY 4: CLINICAL CONTEXT & PATIENT SAFETY

Q9: What is the 'Semantic Gap' you claim to solve?

[5-Second Hook] Translating raw IP/Port packet alerts into bedside patient vitals and clinical mortality hazards.

[Spoken Script] "Traditional IDS software outputs cryptic network logs like 'Alert: IP 192.168.10.45 Port 1883 Variance Anomaly'. To an ICU nurse or physician, this has zero clinical meaning and cannot save a patient. Our system bridges this semantic gap by translating network anomalies directly into Patient Identity (Kamal, Bed 04), Tampered Vitals (Insulin altered from 2 to 25 units/hr), and Clinical Morbidity Hazard (Acute Hypoglycemic Coma), enabling immediate bedside action."

- **Semantic Translation:** Flow IP/MAC -> Patient EHR Name, Age, Diagnosis, and Bed Number.
- **Actionable Insight:** From 'Packet Tampered' to 'Administer IV Dextrose immediately'.
- **Medical Relevance:** Empowers clinical teams without requiring cybersecurity expertise.

Q10: Could your IDS engine crash or interfere with life-support medical devices (Patient Safety)?

[5-Second Hook] Absolutely not; our system uses passive SPAN port packet mirroring with 0.000 ms inline delay.

[Spoken Script] "No, patient safety is completely guaranteed. Our engine connects to the SPAN (Switch Port Analyzer) mirror port of the ICU switch. It inspects mirrored packet copies out-of-band with 0.000 ms inline delay. It does not sit in-line between the medical device and the network, meaning it is physically and logically isolated from the device's actuation and control circuitry."

- **Passive Architecture:** Uses network switch port mirroring (SPAN tap) for zero-risk inspection.
- **0.000 ms Inline Overhead:** Does not delay legitimate patient monitoring signals in transit.
- **Fail-Safe:** Even if the IDS server restarts or goes offline, medical devices continue operating normally.

Q11: Explain the 4 patient attack scenarios briefly.

[5-Second Hook] Kamal (Insulin overdose coma), Sunil (Fake normal ECG shock), Nimali (Ventilator PEEP=0 hypoxia), Anura (Fake BP bleeding shock).

[Spoken Script] "We modeled 4 critical clinical attack vectors: Kamal in Bed 04: Alaris pump L7 MQTT tampering alters insulin from 2 to 25 units/hr, risking fatal hypoglycemic coma. Sunil in Bed 02: Philips ECG L2 ARP cache poisoning replays static 75 bpm normal rhythm, concealing ventricular tachycardia and cardiogenic shock. Nimali in Bed 01: Hamilton ventilator L3 DNS redirect drops PEEP to 0 cmH2O, inducing acute alveolar collapse and hypoxia. Anura in Bed 12: Mindray monitor vitals frozen at 120/80 mmHg, masking acute surgical internal hemorrhage."

- **Bed 04 (Kamal):** L7 MQTT Payload Alteration -> Insulin surge (2 -> 25 u/hr) -> Hypoglycemic Coma.
- **Bed 02 (Sunil):** L2 ARP Poisoning Replay -> Fake normal ECG wave -> Concealed Ventricular Tachycardia.
- **Bed 01 (Nimali):** L3 DNS Broker Redirect -> PEEP dropped to 0 cmH2O -> Acute Atelectasis & Asphyxiation.
- **Bed 12 (Anura):** L7/L2 Telemetry Spoofing -> Frozen 120/80 mmHg -> Concealed Class IV Hypovolemic Shock.

CATEGORY 5: EVALUATION, LATENCY DISCREPANCY & FUTURE DEPLOYMENT

Q12: Why is False Positive Rate (FPR) more important than Accuracy in healthcare?

[5-Second Hook] To eliminate clinical 'Alarm Fatigue'; frequent false alarms cause nurses to ignore real fatal alerts.

[Spoken Script] "Because of clinical Alarm Fatigue. In hospital ICUs, nurses are bombarded by hundreds of device beeps daily. If a cybersecurity IDS produces frequent false alarms, medical staff become desensitized and turn off or ignore alerts, leading to real fatal crises being missed. Our ultra-low 0.0075% False Positive Rate (less than 1 false alarm per 13,000 packets) and 99.95% Precision ensure nurses can trust every single alert that sounds."

- **Clinical Danger:** Frequent false alarms lead directly to nurses muting alarms and patient death.
- **Our Performance:** 0.0075% FPR means over 99.99% of normal packets pass without nuisance alarms.
- **Trust Factor:** High precision guarantees alerts represent authentic life-threatening incidents.

Q13: Why does the top banner show 0.004 ms latency, but the live KPI card shows ~42 to 64 ms?

[5-Second Hook] 0.004 ms is pure CPU model inference; 42-64 ms is full browser-to-server Network Round-Trip Time (RTT).

[Spoken Script] "Sir/Madam, 0.004 ms (4 microseconds) is the pure CPU mathematical inference time of the Random Forest model executing matrix calculations. The 42 to 64 ms displayed on the live KPI card is the full Network Round-Trip Time (RTT), which includes browser HTTP fetch transmission, local JSON serialization, Flask route handling, and UI DOM canvas re-rendering overhead on a local development PC."

- **Model Inference Speed:** 0.004 ms (evaluated on test split using high-resolution perf_counter).
- **Full RTT Latency:** ~40-60 ms (includes browser rendering and HTTP network stack overhead).
- **Compliance:** Pure model speed easily meets the sub-10ms real-time constraint for SDN controllers.

Q14: What are the limitations of your current research?

[5-Second Hook] Evaluation was on benchmark datasets; real deployment requires hospital IRB clinical trials and custom port config.

[Spoken Script] "We acknowledge two primary limitations: First, our evaluation was performed on the benchmark CICIoMT2024 dataset; real-world clinical deployment would require hospital institutional review board (IRB) approval and extensive pilot trials. Second, while our heuristic automatically identifies standard MQTT on ports 1883 and 8883, non-standard proprietary telemetry ports require prior administrative mapping."

- **Clinical Trials:** Requires hospital IRB compliance and validation with live medical hardware.
- **Proprietary Protocols:** Requires port-mapping for non-standard proprietary vendor telemetry buses.
- **Encrypted Payloads:** TLS 1.3 payload encryption requires eBPF socket monitoring or broker-side inspection.

Q15: How would this be deployed in a real hospital in the future?

[5-Second Hook] Containerized microservice connected to ICU switch mirror ports, alerting nursing desks and SDN controllers.

[Spoken Script] "In a real hospital, our detection pipeline would be packaged as a lightweight Docker container deployed on an edge server connected to the ICU switch's SPAN mirror port. Packet flows parsed by eBPF or Zeek would stream into our Flask/FastAPI REST microservice. Detected threats would simultaneously sound alarms on the Central Nursing Station console and push structured JSON mitigation alerts to Member 4's Ryu SDN controller."

- **Edge Deployment:** Docker container running on a secure Linux edge server in the ICU server rack.
- **Traffic Ingestion:** eBPF/Zeek network tap listening on core switch mirrored SPAN port.
- **Dual Alert Dispatch:** Clinician alert on nursing console + JSON mitigation event to SDN controller.

SECTION 6: TECHNOLOGY STACK, TOOLS & PROGRAMMING LANGUAGES USED

This section documents all programming languages, libraries, frameworks, datasets, and engineering tools utilized throughout the design, training, validation, and real-time deployment of **Component 03 (IT23368248)**.

Category	Tools / Libraries / Technology	Purpose in Component 03
Programming Languages	• Python (v3.13) • JavaScript (ES6+) • HTML5 & CSS3 • PowerShell / Bash	Core ML training, Flask REST API, interactive dynamic dashboard, audio synthesis, and build automation.
Machine Learning & Data Science	• Scikit-Learn (v1.5+) • Pandas & NumPy • Joblib • Imbalanced-Learn (SMOTE)	Random Forest classifiers (Stage 1 & 3), feature engineering, balanced class weighting, and model persistence.
API & Web Architecture	• Flask (v3.0+) • Flask-CORS • RESTful JSON Endpoints • Asynchronous Fetch API	Microservice serving /predict and /alerts endpoints with sub-millisecond dispatch and cross-origin handling.
Visualization & Audio Synthesis	• Chart.js (v4.4+) • Web Audio API • KaTeX Math Rendering • CSS Grid & Flexbox	Real-time dynamic line chart, zero-latency 1050 Hz non-rhythmic medical warning beep, and responsive UI layout.
Datasets & Evaluation Benchmarks	• CICIoMT2024 (Primary) • CICIoT2023 (Merged) • Scikit-Learn Metrics API	40+ medical devices with authentic MITM attacks, merged for Stage 1 IoMT classification and 5-fold cross-validation.
Networking & Medical Protocols	• MQTT (Ports 1883 / 8883) • ARP (Layer 2) • DNS (Layer 3) • TCP/UDP (Layer 4)	Protocol flow heuristics, gratuitous ARP conflict detection, rogue broker DNS redirection, and dosage payload monitoring.
DevOps & Version Control	• Git & GitHub • Python venv • ReportLab (PDF Engine)	Branch management, clean chronological commit history, automated documentation, and PDF generation.

Individual Research Integrity Statement:
All algorithms, feature extraction scripts, ML pipelines, deterministic correlation heuristics, RESTful APIs, and dashboard interfaces for Component 03 were developed independently by **S.M. Dissanayaka (IT23368248)** in full alignment with SLIIT research project guidelines.